

Jour 1

Présentation du RGPD

1. Qu'est-ce que le RGPD ?

Le **RGPD**, ou **Règlement Général sur la Protection des Données**, est un règlement européen entré en application le **25 mai 2018**. Il a pour objectif de protéger les données personnelles des personnes et de leur donner davantage de contrôle sur leurs informations.

2. Pourquoi le RGPD existe-t-il ?

Le RGPD a plusieurs objectifs principaux :

- **Protéger la vie privée** : il permet aux citoyens d'avoir davantage de contrôle sur leurs informations personnelles face au développement du numérique et du ciblage publicitaire.
- **Responsabiliser les entreprises** : il oblige les organisations à protéger les données personnelles et à être transparentes sur leur utilisation.
- **Harmoniser les règles** : il permet d'avoir un cadre commun de protection des données dans l'ensemble de l'Union européenne.

3. Depuis quand le RGPD s'applique-t-il ?

Le RGPD s'applique depuis le **25 mai 2018**.

- **24 mai 2016** : entrée en vigueur du règlement. Le texte a été adopté et publié.
 - **25 mai 2018** : entrée en application. Les entreprises et organisations doivent respecter les règles du RGPD.
 - **2016 à 2018** : période de transition de deux ans permettant aux organisations de se préparer à ces nouvelles obligations.
-

Les notions importantes du RGPD

4. Qu'est-ce qu'une donnée personnelle ?

Une **donnée personnelle** est toute information permettant d'identifier une personne physique, directement ou indirectement.

Exemples :

- nom ;
- adresse ;
- adresse e-mail ;
- numéro de téléphone ;
- identifiant en ligne.

Exemple chez X-corp :

L'adresse e-mail d'un client enregistrée dans **DataManage** est une donnée personnelle.

5. Qu'est-ce qu'un traitement de données ?

Un **traitement de données** correspond à pratiquement toute opération effectuée sur des données personnelles.

Il peut s'agir de :

- collecter ;
- enregistrer ;
- stocker ;
- consulter ;
- modifier ;
- transmettre ;
- supprimer.

Exemple chez X-corp :

X-corp récupère l'adresse e-mail d'un client et la stocke dans **DataManage**. Il s'agit d'un traitement de données personnelles.

6. Responsable du traitement

Le **responsable du traitement** est l'organisme qui détermine **pourquoi** les données sont utilisées et **comment** elles vont être traitées.

Exemple :

Si **RetailCo** décide pourquoi et comment les données de ses clients doivent être utilisées, RetailCo peut être responsable du traitement, tandis que X-corp peut agir comme sous-traitant.

7. Sous-traitant

Le **sous-traitant** est une organisation qui traite les données **pour le compte du responsable du traitement**.

Exemple :

RetailCo demande à X-corp d'utiliser **DataManage** pour gérer les données de ses clients.

- **RetailCo** : peut être responsable du traitement.
- **X-corp** : peut être sous-traitant.

8. Le DPO

DPO signifie **Data Protection Officer**, soit **Délégué à la Protection des Données**.

Son rôle est notamment de superviser et de conseiller l'organisation concernant sa conformité au RGPD.

Chez X-corp :

Le sujet indique qu'un DPO a déjà été nommé. C'est donc un élément positif dans l'organisation de la conformité RGPD de X-corp.

9. Les bases légales

Pour traiter des données personnelles, une organisation doit disposer d'une **base légale**.

Les principales bases légales sont :

- le consentement ;
- l'exécution d'un contrat ;
- le respect d'une obligation légale ;
- la sauvegarde des intérêts vitaux ;
- une mission d'intérêt public ;
- l'intérêt légitime, sous certaines conditions.

Chez X-corp :

- **RetailCo** : consentement ;
- **HealthMed** : consentement explicite ;
- **EduLearn** : consentement.

X-corp rencontre cependant des difficultés pour **gérer et documenter les consentements**, notamment pour les campagnes marketing réalisées avec AutoMail. Ce point devra donc être vérifié lors de l'audit.

Les 7 principes du RGPD

10. Licéité, loyauté et transparence

L'entreprise doit avoir une base légale et expliquer clairement aux personnes ce qu'elle fait avec leurs données.

Exemple :

X-corp doit expliquer clairement pourquoi elle collecte l'adresse e-mail d'un client et comment cette donnée sera utilisée.

Conclusion

Pour conclure, le RGPD est un règlement qui permet de **protéger les données personnelles** et de donner davantage de contrôle aux personnes sur leurs informations.

Pour une entreprise comme **X-corp**, cela signifie qu'elle doit savoir **quelles données elle collecte, pourquoi elle les utilise, combien de temps elle les conserve et comment elle les protège**.

X-corp possède déjà plusieurs mesures positives, comme le **chiffrement, la double authentification, le contrôle des accès et la présence d'un DPO**. Cependant, certains points doivent encore être améliorés, notamment **la gestion des consentements et des demandes des utilisateurs**.

L'objectif de notre audit sera donc de vérifier si X-corp respecte réellement les règles du RGPD et de proposer des améliorations lorsque cela est nécessaire.

Jour 2

 Registre des activités de traitement RGPD - X-corp (Art. 30).xlsx

Jour 3

 Rapport PIA.pdf

Jour 4

1. **Étape 1 : Détection de l'incident / Signalement**

Ici, la personne qui détecte l'incident doit transmettre les informations qu'elle possède au DPO/Responsable de la sécurisation des données.

2. **Étape 2 : Gestion court terme**

Dans cette étape, il faut déterminer comment les données ont été compromises. C'est aussi là qu'une première évaluation doit être mise en place. Quels sont les systèmes impactés ? D'où peut provenir l'incident ? Évaluer le nombre de personnes impactées. Tout ce qui permet d'avoir une idée globale du problème. Une fois cette brève analyse faite, une isolation des systèmes touchés peut être réalisée et une première correction de faille peut être exécutée en parallèle. Il faut stopper l'hémorragie le plus vite possible.

3. **Étape 3 : Communication**

Pendant que les équipes techniques travaillent, une communication doit être faite afin de fournir tous les éléments de la situation à différents partis. Il est important de déterminer qui doit être contacté et à quelle échelle. Alerter les autorités compétentes ? Informer les personnes concernées ? Quelles informations peuvent être communiquées ? Nommer un référent pour répondre à d'éventuelles interrogations ?

4. **Étape 4 : Analyse / Gestion moyen terme**

Une fois l'urgence passée, une analyse profonde doit être effectuée : vérification des logs, détermination de la nature de la faille, création d'une solution instantanée, estimation précise de l'ampleur des dégâts, détermination des conséquences possibles ou encore déterminer la sensibilité des données fuitées. Une fois cette enquête réalisée il faut déployer une solution pansement le temps de trouver une solution pérenne.

5. **Étape 5 : Informations complémentaires**

La communication interne et la sensibilisation des équipes sujettes vont être des enjeux majeurs une fois que la poussière est retombée. Il est nécessaire d'expliquer ce qui a causé l'incident et toutes les actions entreprises, ou qui vont l'être, afin de gérer le problème. Dans ce genre de cas l'information prévaut sur beaucoup d'autres aspects car la majorité des failles sont d'origines humaines.

6. **Étape 6 : Déploiement d'un correctif**

C'est l'étape la plus simple, une question doit être posée : qu'est-ce que l'on peut mettre en place pour éviter qu'une situation similaire se reproduise ? On peut citer par exemple : une amélioration de la procédure de gestion des incidents, augmenter la clarté des rôles et des responsabilités de chacun, renforcer la surveillance, améliorer les détections d'intrusion ou alors documenter les incidents précédents et les mesures prises. C'est pendant cette période que nous devons réfléchir à la relation de causalité entre tous les éléments qui sont intervenus lors de l'incident. C'est l'occasion de développer une solution long terme permettant d'éviter des incidents similaires.

Jour 5 : Audit RGPD

Observations X-Corp	Exigences RGPD	Conclusion
Difficultés à gérer et documenter les consentements. Notamment pour les campagnes marketing via AutoMail.	Le consentement doit être libre, spécifique, éclairé et démontable par le DPO. Article 5 et 7	Il faut vérifier et renforcer la capacité à prouver le consentement des utilisateurs.
Réception de 50 à 100 demande d'accès par mois, cela peut constituer une problématique récurrente.	Les demandes d'accès ou de droits doivent être traités dans un délai d'un mois. (Possibilité d'extension dans certains cas) Article 12	Il faut démontrer qu'il existe une procédure de gestion de demande d'accès et des moyens suffisants pour respecter les délais.

Observations X-Corp	Exigences RGPD	Conclusion
Une fuite de données concernant 2000 enregistrements clients, la gestion de cet incident a révélé des lacunes dans le processus de réponse.	Une fuite présentant un risque doit être analysée et éventuellement notifiée à l'autorité compétente dans les délais prévus. Si le risque est élevé, les personnes concernées doivent être informées. Article 33 et 34	Il faut vérifier l'analyse réalisée et apporter des correctifs si nécessaire.
Conservations des données de HealthMed sur une durée de 10 ans après la fin du traitement médical. La justification de cette durée doit pouvoir être prouvée.	Les données personnelles ne doivent pas être conservées plus que nécessaire par rapport à leur finalité ou d'une obligation applicable. Article 5	Il faut vérifier la base légale et l'obligation qui peuvent permettre de justifier la durée de 10 ans.
Manque de précisions sur l'encadrement contractuel RGPD des relations avec CloudSecure et AdBoost.	Si un prestataire agit en tant que sous-traitant, la relation doit être encadrée conformément aux exigences de l' article 28 .	Il faut déterminer le rôle précis de chaque partenaire et contrôler les contrats, garanties et responsabilités de chacun.
HealthMed traite des données à risque. X-Corp possède de mesures générales de sécurité mais l'adaptation spécifique aux données de santé n'est pas détaillée.	Les données de santé constituent une catégorie particulière de données. Le traitement est soumis à des conditions spécifiques. Les mesures de sécurité doivent être adaptées aux risques. Article 9	Il faut s'assurer que les moyens techniques et organisationnels sont en adéquations avec le risque que représentent ces données.
Le registre de données n'est pas explicitement disponible.	Le DPO doit tenir et maintenir à jour un registre des activités de traitement de données. Article 30	Il faut vérifier l'intégrité du registre des activités de traitement.
DataManage, MarketInsight et AutoMail permettent une personnalisation de l'offre.	Les données sont collectées pour certaines finalités déterminées et ne doivent pas être réutilisées d'une autre manière. Article 5	Il faut s'assurer que la circulation de données et que les finalités respectent le cadre légal.
MarketInsigh utilise des techniques IA pour produire des recommandations personnalisées. Il n'est pas précisé la nature	Les traitements impliquant du profilage ou des décisions automatisées entraînent parfois des obligations particulières de	Il faut déterminer si le traitement relève du profilage ou de la décision automatisée ce qui

Observations X-Corp	Exigences RGPD	Conclusion
exacte du profilage ni les informations communiquées aux personnes.	transparence ou de protection des droits. Article 22, 13 et 14	implique de vérifier les obligations de transparence associées.
Aucune précision géographique du stockage des données par CloudSecure.	Les transferts de données vers des pays tiers doivent respecter les conditions prévues et être encadrées par un mécanisme approprié. Article 44 à 49	Il faut vérifier si des données sont transférées en dehors de l'UE et la localisation précise du stockage.
Manque de détails concernant les moyens, le niveau d'implication et l'autonomie du DPO.	Le DPO doit pouvoir exercer ses missions de manière effective et avec les moyens d'agir en toute indépendance. Article 38 et 39	Il faut s'assurer que le DPO puisse être en capacité de réaliser l'entièreté de ses fonctions.
Une DPIA est nécessaire afin de réévaluer les produits après leurs lancements.	Une DPIA doit être réexaminée lorsque des changements peuvent affecter le niveau de risque. Article 35	Il faut contrôler les DPIA existants et contrôler s'il existe des réévaluations lors des évolutions de traitements ou de risques.

